

Aufgabenblatt für das Webshopprojekt

OWASP Top 10 2025 | Gruppenarbeit | insgesamt 25 Punkte

1 Euer Auftrag

Entwickelt als Gruppe einen eigenen Webshop mit einer Aufgabenplattform. Andere Studierende sollen daran Hacking-Challenges bearbeiten und die Ursachen der Sicherheitsprobleme verstehen. Plant die Architektur, stellt die Infrastruktur bereit und setzt eure Lösung bis zur Präsentation um.

Vorgabe	Verbindlicher Umfang
OWASP-Themen	Drei unterschiedliche Kategorien der OWASP Top 10:2025: eine wird vorgegeben, zwei wählt ihr selbst.
Challenges	Mindestens eine Challenge je Kategorie. Nennt je Challenge die genaue CWE und gegebenenfalls CVE mit offizieller Quelle.
Technologie	Programmiersprache, Frameworks und Datenbank sind frei wählbar. Begründet eure Auswahl.
Hosting	Intern auf dem bereitgestellten Ubuntu-Server über Proxmox. Server und grundlegende Infrastruktur werden bereits in Session 1 eingerichtet und getestet.
Quellcode	Über ein Git-Repository auf GitHub, GitLab oder einer vergleichbaren Plattform. Die Lehrperson benötigt Zugriff.
Fertigstellung	Session 3 am 6. November 2026: Software, Dokumentation und Präsentation sind fertig.

Kategorien und Nummern: [OWASP Top 10 2025](#)

2 Eure drei Meilensteine

Session	Ergebnis für die Bewertung	Punkte
1 Kickoff	Entwurf, ausgewählte Challenges, aufgesetzter Ubuntu-Server und getestete Infrastruktur. Am Ende Shop-IP mitteilen.	5
2 Coaching	Vollständige Anforderungen, Architektur, Challenge-Steckbriefe und Umsetzungsplanung vorstellen.	7
3 Präsentation 6. November 2026	Fertige intern gehostete Software, Dokumentation und Repository. 20 Minuten Präsentation je Gruppe einschließlich praktischer Demo.	13
Gesamt	Alle drei Meilensteine zählen zur Bewertung.	25

3 Umfang eurer Software

- Webshop: Definiert normale Shop-Abläufe und integriert eure drei Sicherheitsprobleme. Verwendet fiktive Daten und simulierte externe Abläufe, etwa Zahlungen.
- Aufgabenplattform: Zeigt alle Challenges mit Ziel, Kategorie, Einstieg, Vorbedingungen und Erfolgskriterium. Der Lösungserfolg muss objektiv überprüfbar sein.

Die User Stories US01 bis US05, US08 und US09 am Ende dieses Aufgabenblatts definieren den verbindlichen Mindestumfang des Shops und die Abnahme. Alle sieben Stories sind Pflicht. Die Anforderungen an Challenges stehen separat in Abschnitt 8; eine dokumentierte manuelle Lösungsprüfung genügt.

Session 1 Entwurf und Infrastruktur

Ergebnis: Nach Session 1 liegt ein erster Entwurf vor und euer Ubuntu-Server ist aufgesetzt. Die grundlegende Infrastruktur ist getestet. Fertige Shopfunktionen werden hier noch nicht verlangt.

4 Zugänge und IP Adressen

Für die Anmeldung bei neta.hcw.ac.at und proxmox.hcw.ac.at können eure Zugangsdaten vom HCW-Portal genutzt werden.

Jede studierende Person findet drei nutzbare IP-Adressen unter neta.hcw.ac.at/dashboard/virtual-lab/servers. Wählt als Gruppe daraus die für euren Shop vorgesehene IP-Adresse und haltet die Zuordnung zu eurem Server fest.

Unter proxmox.hcw.ac.at könnt ihr euch mit euren Zugangsdaten vom HCW-Portal anmelden. Dort findet ihr den bereitgestellten Ubuntu-Server, den ihr in dieser Session aufsetzt und für euer Projekt vorbereitet.

Die WireGuard-Konfiguration findet ihr unter neta.hcw.ac.at/dashboard/wireguard. Nutzt diese Konfiguration, um über WireGuard direkt mit eurem Server zu interagieren.

5 Was ihr in Session 1 erledigt

- Konzept entwerfen: Shop-Idee, Plattformname, Benutzerabläufe, Technologieauswahl und erste überprüfbare Anforderungen festhalten. Erstellt eine grobe Architekturskizze.
- Challenges auswählen: Eine vorgegebene und zwei freie OWASP-Kategorien mit konkreten Challenge-Ideen. Nennt die passenden CWE-IDs mit Bezeichnung und Quelle sowie gegebenenfalls CVE-IDs.
- Ubuntu-Server aufsetzen: Server in Proxmox identifizieren, starten und die Ubuntu-Installation oder Ersteinrichtung entsprechend der bereitgestellten Umgebung abschließen. Prüft die Anmeldung und den administrativen Zugang.
- Infrastruktur testen: WireGuard-Verbindung sowie Erreichbarkeit der gewählten Server-IP von eurem Arbeitsrechner prüfen, etwa über SSH oder eine Testwebseite. Dokumentiert Test, erwartetes Ergebnis und tatsächliches Ergebnis. Die Proxmox-Konsole allein belegt die Erreichbarkeit über WireGuard nicht.

Am Ende von Session 1 teilt ihr dem Vortragenden Plattformname, Rechner-/VM-Bezeichnung und die genaue IP-Adresse mit, unter der der Shop erreichbar sein wird.

6 Bewertung nach Session 1

Nachweis	Punkte
Shop-Konzept und begründete Technologieauswahl; Plattformname und Hosting-Rechner benannt.	1
Erste überprüfbare Anforderungen und grobe Architekturskizze.	1
Drei OWASP-Kategorien und Challenge-Ideen mit genauen CWE-/CVE-Zuordnungen und Quellen.	1
Ubuntu-Server aufgesetzt, laufend und administrativer Zugang getestet.	1
Erreichbarkeit über WireGuard getestet und Shop-IP am Session-Ende dem Vortragenden mitgeteilt.	1
Summe Session 1	5

Session 2 Vollständige Planung

Ergebnis: Zeigt im Coaching ein vollständiges, umsetzbares Konzept für Software, Challenges und internen Betrieb. Erklärt eure Entscheidungen und klärt offene Punkte. Die Implementierung muss hier noch nicht fertig sein.

7 Inhalt und Bewertung der Planung

Nachweis	Punkte
Vollständige Planung der Pflichtstories US01 bis US05, US08 und US09 mit überprüfbaren Abnahmekriterien.	1
Sicherheitsanforderungen mit überprüfbaren Abnahmekriterien.	1
Architekturdiagramm mit Komponenten, Datenspeichern, Datenflüssen und Vertrauensgrenzen.	1
Konkrete Kontrollstellen und Schutzgrenzen für Server, Plattform und andere Gruppen.	1
Begründete Architektur- und Technologieentscheidungen; mindestens eine Alternative mit konkreter Abwägung.	1
Drei vollständige Challenge-Steckbriefe mit fachlich begründeter CWE-/CVE-Zuordnung.	1
Arbeits- und Betriebsplan: Verantwortlichkeiten, Git-Repository, Laufzeitvoraussetzungen, Hosting, Start und Reset.	1
Summe Session 2	7

8 Steckbrief für jede Challenge

- Zuordnung: Titel, OWASP-ID 2025 und mindestens eine konkrete passende CWE-ID mit Bezeichnung, offizieller Quelle und kurzer Begründung. Bei einem bekannten Fall zusätzlich CVE-ID, Originalprodukt und betroffene Version; sonst „keine CVE - eigene Umsetzung“.
- Spielbare Aufgabe: Lernziel, Ursache, verletzte Sicherheitsregel, Auftrag, Einstieg, Vorbedingungen und Testkonten; Hinweise, soweit vorgesehen.
- Lösung und Nachweis: Reproduzierbarer Lösungsweg, erwartete Sicherheitswirkung und objektiv prüfbares Erfolgskriterium, etwa Flag, Zustand, Artefakt oder Ereignis.
- Reset: Wie wird der Ausgangszustand wiederhergestellt, damit die Aufgabe erneut bearbeitet werden kann?
- Sichere Korrektur: Konkreter Patch, Konfigurationsänderung oder Architekturentwurf; passender Test mit Eingabe und erwartetem Ergebnis.

CWE beschreibt die Art der Schwäche, CVE einen veröffentlichten konkreten Produktfall. Kennzeichnet vereinfachte Umsetzungen als „didaktische Nachbildung mit Bezug auf CVE-...“. Musterlösungen und Gegenmaßnahmen stellt ihr der Lehrperson separat von den spielbaren Aufgaben bereit.

Erläuterung: [CWE und CVE](#)

Session 3 Fertige Lösung und Abgabe

9 Präsentation am 6. November 2026

Am 6. November 2026 sind Software und Unterlagen fertig. Jede Gruppe hat insgesamt 20 Minuten für die Endpräsentation einschließlich praktischem Teil.

Zeitvorschlag: 5 Minuten Konzept und Architektur, 10 Minuten praktische Live-Demo, 5 Minuten Gegenmaßnahmen und Fragen. Rückfragen sind in den 20 Minuten enthalten.

Zeigt am laufenden Shop mindestens eine repräsentative Challenge live: Ausgangszustand, Bearbeitung und überprüfbaren Lösungserfolg. Erläutert Ursache, sichere Gegenmaßnahme und erwartetes sicheres Verhalten. Alle drei Challenges sind funktionsfähig und dokumentiert.

Bewertung der fertigen Lösung	Punkte
Drei Challenges: je 2 Punkte für korrekte CWE-/CVE-Umsetzung und reproduzierbaren Lösungserfolg.	6
Aufgabenplattform: verständliche Aufgaben und überprüfbarer Lösungserfolg.	2
Shopablauf und Betrieb: US01 bis US05, US08 und US09, Start, Reset, Proxmox-Hosting und wirksame Schutzgrenzen.	2
Konkrete sichere Korrekturen für alle drei Challenges.	1
Passende Prüfscenarien für alle drei sicheren Korrekturen.	1
20-Minuten-Präsentation mit praktischer Challenge-Demo, Entscheidungen und Einordnung.	1
Summe Session 3	13

10 Quellcode und Unterlagen bereitstellen

Stellt den Quellcode über GitHub, GitLab oder eine vergleichbare Git-Plattform bereit. Teilt den Repository-Link und die geprüfte Version mit. Ein privates Repository ist mit Zugriff für die Lehrperson möglich.

Unterlage	Inhalt
Repository	Shop und Plattform, Abhängigkeitsdefinitionen, Konfigurationsvorlagen und klar gekennzeichnete Abgabestand, etwa Commit oder Tag.
Konzept	Vollständige Anforderungen, Architekturdiagramm, Entscheidungen und Arbeitsaufteilung.
Challenges	Drei Steckbriefe mit genauen CWE-/CVE-Zuordnungen, Quellen, Musterlösungen, Korrekturen und Prüfscenarien. Lösungen separat für die Lehrperson.
Betriebsanleitung	Shop-IP und interne URL, Voraussetzungen, Testdaten, Start, Stop und Reset; Nachweis des laufenden Shops auf Proxmox.

11 Regeln für den internen Betrieb

- Nutzt eure freigegebenen IP-Adressen und Server. Begrenzt Angriffe auf die vorgesehenen Challenge-Bereiche, sodass andere Gruppen und die Hosting-Umgebung geschützt bleiben.
- Testet ausschließlich freigegebene Challenge-Ziele. Proxmox, WireGuard und weitere Hochschulsysteme sind keine Challenge-Ziele. Infrastruktur-Zugangsdaten bleiben außerhalb von Code und Abgabe.

User Stories für den Einkauf

US01 bis US05, US08 und US09 sind Pflicht. Plant ihre Umsetzung in Session 2 und weist sie in Session 3 nach. Die Kriterien beschreiben den normalen Gebrauch mit fiktiven Daten. Bewusste Sicherheitsabweichungen müssen einer Challenge zugeordnet und dokumentiert sein; der normale Kaufprozess bleibt durchführbar.

US01 Produktkatalog ansehen

Als Kundin oder Kunde möchte ich die verfügbaren Produkte ansehen, damit ich Produkte für meinen Einkauf auswählen kann.

- US01-AK1: Der Katalog zeigt mindestens fünf fiktive Produkte mit eindeutiger Kennung, Name und Preis in Euro.
- US01-AK2: Jedes Produkt kann aus dem Katalog heraus ausgewählt werden; die Auswahl öffnet die passende Detailansicht.
- US01-AK3: Katalog und Detailansicht verwenden dieselben Produktdaten und Preise.

US02 Produktdetails ansehen

Als Kundin oder Kunde möchte ich die Beschreibung eines Produkts lesen, damit ich entscheiden kann, ob ich es kaufen möchte.

- US02-AK1: Die Detailansicht zeigt Kennung, Name, Beschreibung und Preis des ausgewählten Produkts.
- US02-AK2: Von der Detailansicht kann ich zum Katalog zurückkehren und das Produkt in den Warenkorb legen.
- US02-AK3: Ein unbekanntes Produkt wird verständlich als nicht vorhanden angezeigt.

US03 Warenkorb bearbeiten

Als Kundin oder Kunde möchte ich Produkte und Mengen in meinem Warenkorb bearbeiten, damit ich meinen Einkauf zusammenstellen kann.

- US03-AK1: Produkte können hinzugefügt, Mengen auf positive ganze Zahlen geändert und Positionen entfernt werden.
- US03-AK2: Der Warenkorb zeigt je Position Produkt, Menge, Einzelpreis und Zwischensumme sowie die Gesamtsumme. Summen stimmen für gültige Eingaben.
- US03-AK3: Der Warenkorb bleibt beim Wechsel zwischen Shopseiten erhalten. Ein leerer Warenkorb wird verständlich angezeigt.

User Stories für Bestellung und Shopbetrieb

US04 Bestellung simuliert abschließen

Als Kundin oder Kunde möchte ich meinen Warenkorb bestellen, damit ich den vollständigen Kaufprozess testen kann.

- US04-AK1: Vor dem Abschluss sehe ich eine Bestellübersicht mit Produkten, Mengen und Gesamtsumme.
- US04-AK2: Ein nicht leerer Warenkorb kann über eine eindeutig als Simulation bezeichnete Aktion bestellt werden. Ein leerer Warenkorb erzeugt keine Bestellung.
- US04-AK3: Es werden nur fiktive Bestelldaten und simulierte Zahlungen verwendet. Eine Bestellung löst weder eine reale Zahlung noch Versand aus.

US05 Bestellbestätigung erhalten

Als Kundin oder Kunde möchte ich eine Bestätigung meines Einkaufs erhalten, damit ich meine Bestellung nachvollziehen kann.

- US05-AK1: Nach dem Abschluss erscheinen eine eindeutige Bestellnummer, die bestellten Positionen und die Gesamtsumme.
- US05-AK2: Die Bestellung wird serverseitig gespeichert und stimmt im normalen Ablauf mit der bestätigten Übersicht überein. Die Speicherung ist nachweisbar.
- US05-AK3: Der Warenkorb ist nach erfolgreicher Bestellung leer; ein weiterer Einkauf ist möglich.

Shopbetrieb und Testkonten

US08 Ausgangszustand wiederherstellen

Als Betreiberin oder Betreiber möchte ich den Shop zurücksetzen, damit Einkäufe wiederholt getestet werden können.

- US08-AK1: Ein dokumentierter Befehl, ein Skript oder eine Oberfläche stellt Produkte und Testkonten wieder her und setzt Warenkörbe und Bestellungen auf den dokumentierten Ausgangszustand zurück.
- US08-AK2: Nach dem Reset funktionieren Testkonten und der normale Kaufprozess erneut.
- US08-AK3: Das Git-Repository beschreibt Voraussetzungen, Start und Reset so, dass die Lehrperson sie ausführen kann.

US09 Testkonten nutzen

Als Kundin oder Kunde möchte ich mich mit einem Testkonto anmelden, damit ich meine Einkäufe durchführen und meine Bestellungen ansehen kann.

- US09-AK1: Mindestens zwei fiktive Kundenkonten sind vorbereitet. Anmelden und Abmelden funktionieren.
- US09-AK2: Bestellungen sind dem jeweiligen Testkonto zugeordnet. Angemeldete Kundinnen und Kunden können ihre eigenen Bestellungen mit Bestellnummer, Positionen und Gesamtsumme ansehen. Bewusste Abweichungen bei Zugriffsrechten sind als Challenge dokumentiert.

Optionale Erweiterungen: Suche, Filter, Bilder, Registrierung, Gutscheine, Lagerverwaltung, Admin-Oberfläche, automatische Erfolgsprüfung und Leaderboard. Sie ersetzen keine Pflichtstory und ergeben keine zusätzlichen Punkte.